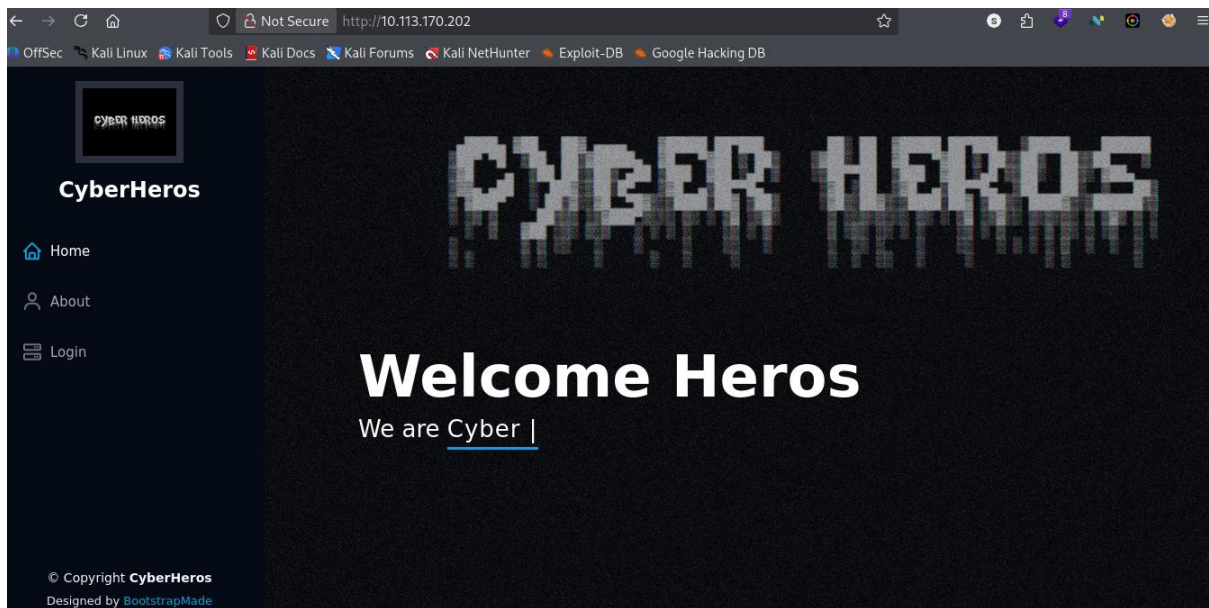


Cyber Heroes Write-up THM

“Want to be a part of the elite club of CyberHeroes? Prove your merit by finding a way to log in!”

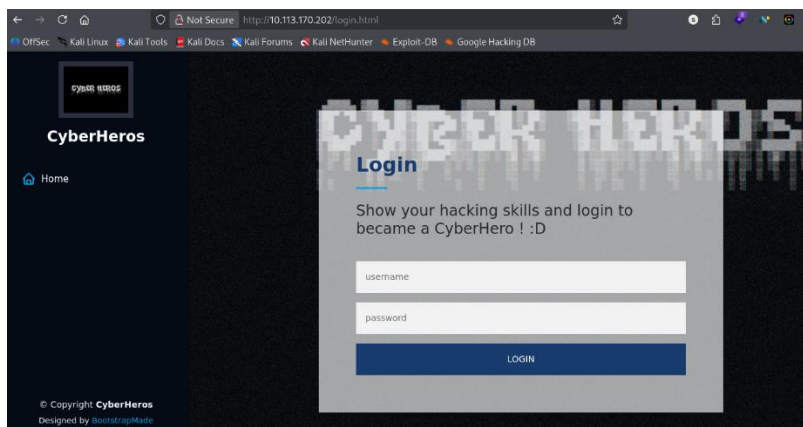
```
Nmap scan report for 10.113.170.202
Host is up (0.17s latency).
Not shown: 64657 closed tcp ports (reset), 876 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.48 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 729.34 seconds
```



After doing the Nmap scan and finding the running HTTP service, we land on this welcome page.

As per custom, we explore the page and lookout for any interesting features or information. We can see a login tab on the left panel.



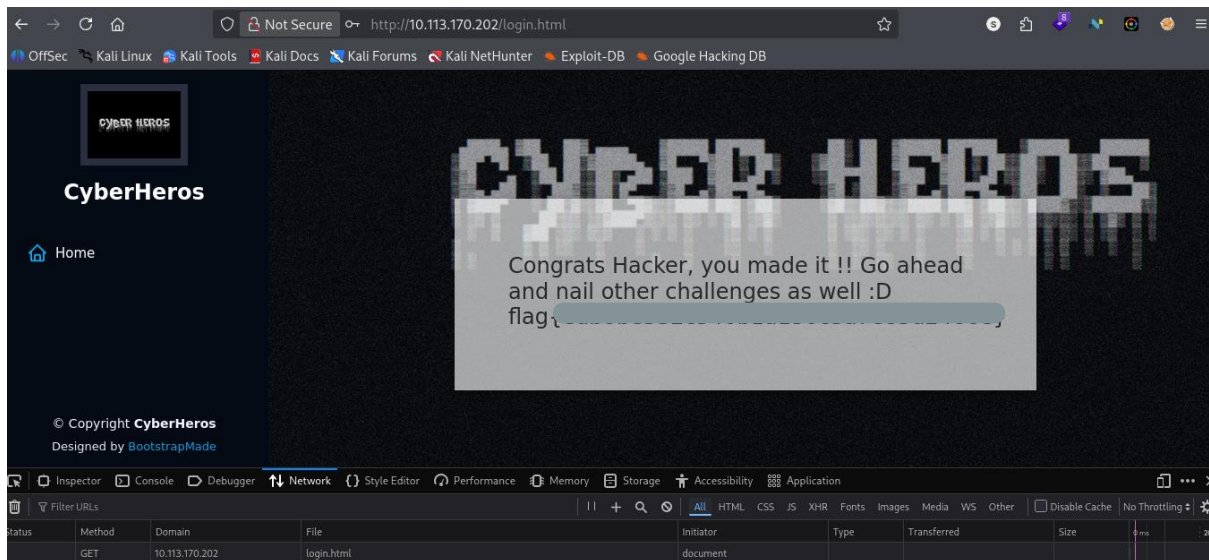
The screenshot shows a web browser window with the address bar displaying `http://10.113.170.2/login.html`. The browser's tab bar shows several open tabs, including 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The main content area displays the 'CyberHer0s' login page, which features a dark background and a 'Login' button. A modal dialog box is overlaid on the page, showing the IP address '10.113.170.2' and the message 'Incorrect Password, try again.. you got this hacker !' with an 'OK' button. The browser's developer tools are open at the bottom, showing the Network tab with a list of requests including 'login.html', 'aos.css', and 'bootstrap.min.css'.

```

122 <script>
123
124 function authenticate()
125 {
126   a = document.getElementById('uname');
127   b = document.getElementById('pass');
128   const ReverseString = str => [...str].reverse().join('');
129   if (a.value=="hacker" & b.value==ReverseString("hacker")) { |
130     var xhttp = new XMLHttpRequest();
131     xhttp.onreadystatechange = function() {
132       if (this.readyState == 4 && this.status == 200) {
133         document.getElementById("flag").innerHTML = this.responseText ;
134         document.getElementById("todel").innerHTML = "";
135         document.getElementById("rm").remove() ;
136       }
137     };
138     xhttp.open("GET", "RandomLo0o0o0o0o0o0o0o0o0o0o0o0gpath12345_Flag_"+a.value+"_"+b.value+".txt", true);
139     xhttp.send();
140   }
141   else {
142     alert("Incorrect Password, try again.. you got this hacker !")
143   }
144 }
145 </script>
146
147 <footer id="footer">
148 <div class="container">
149 <div class="copyright">
150   <copy> Copyright <strong><span>CyberHeros</span></strong>
151 </div>
152 <div class="credits">

```

As suspected, by looking at the conditional statements in the code, we find the code that handles the login, and it is so simple that the correct credentials are hardcoded. We use the given credentials, and that's it; we have successfully logged in (Notice how the password is reversed).



In this assessment, we found that the credentials were hardcoded into the source code. Developers should avoid such mistakes, as attackers could easily uncover sensitive data like this and compromise the target.